ClinicShield

Owner summary

Assessment time: 2026-11-08T18:03:24.140304+00:00
Fictional example: lakeview_dental
Evidence mode: documented fictional scenario
Demo only. These changes are made-up assumptions. They are not completed corrective actions or verified improvement.

65/100 | At risk

Safeguards 72.3/100 | Exposure 55.0/100
Weighting: 60% Safeguards + 40% Exposure. Status: provisional
Safeguards shows how your answers scored. Exposure starts at 100 and drops for confirmed technical findings. A higher score does not prove that your systems are safe. Provisional means there are gaps or checks still open.

Read the score with its limits

6 coverage issues | 28 finding groups need review.
Missing evidence is not proof of safety. Scores use only the data supplied. Draft mappings may still need review. This prototype does not prove that a clinic is safe, meets health care law or is ready for live use.
- Some source or inventory coverage is unassessed.
- Some findings require verification.
- Some applied rule definitions remain drafts.

Fix First: highest-ranked actions

Priority is finding points divided by effort. It does not predict a score gain or a drop in real risk. Check costs and the work needed before you start.

#1 | R05 | device:LV-LT01
Check whether device encryption is on. Encryption scrambles stored data so a key is needed to read it. If it is off, ask the IT admin to turn on a ...
Owner: IT administrator or managed service provider | Effort: 2/3 | Cost: unknown

#2 | R10 | device:LV-RT01
Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. S...
Owner: Device administrator or responsible vendor | Effort: 2/3 | Cost: unknown

#3 | R07 | assessment
Check each safeguard in Q17 on its own. Find remote links that are not needed. Check the login checks on each link that stays on. Plan fixes with t...
Owner: IT administrator and remote-access service owner | Effort: 2/3 | Cost: unknown

Next: agree owners, confirm evidence and request provider estimates. The appendix contains all actions, evidence, score arithmetic and coverage warnings. Summary labels may be shortened.

Detailed appendix

Full report including findings requiring verification. Unsupported glyphs are shown as [U+code].

ClinicShield assessment
Fictional clinic: lakeview_dental
Evidence mode: documented fictional scenario
Demonstration only; not an assessment of a real clinic. Any scenario evidence is synthetic, and its timestamps represent fixture generation rather than real-world verification. Live threat-intelligence caches are not loaded.

Assessment time: 2026-11-08T18:03:24.140304+00:00

Overall score: 65/100 - At risk
Score status: provisional
Safeguards score: 72.3/100
Exposure score: 55.0/100
Overall weighting: 60% Safeguards and 40% Exposure.

How to read this report

Safeguards shows how your answers scored. Exposure starts at 100 and drops for confirmed technical findings. A higher score does not prove that your systems are safe. Provisional means there are gaps or checks still open.
Missing evidence is not proof of safety. Scores use only the data supplied. Draft mappings may still need review. This prototype does not prove that a clinic is safe, meets health care law or is ready for live use.

Word guide

IT / NA / VPN / SMB / BAA: Information technology / not applicable / virtual private network / Server Message Block file sharing / Business Associate Agreement. A VPN alone does not prove that access is safe.
Finding: A gap or a check raised by the supplied data. Confirmed means supported by that data, not an on-site check.
Coverage: What the tool could check. Unassessed means it could not check; it does not mean safe.
Entity: A device, cloud service or other item used to group scores. A cap sets the most points one item can lose.
Effort: 1: under an hour and free. 2: a day or a small cost. 3: vendor help, budget or several weeks.
CSV / JSON / XLSX / XML / TXT / PDF: Comma-separated values / JavaScript Object Notation / Excel workbook / Extensible Markup Language / plain text / Portable Document Format. These are file types.
OS / MFA / EHR / PHI: Operating system / multifactor authentication / electronic health record / protected health information. Do not upload patient data.
CVE / NVD / CVSS: Common Vulnerabilities and Exposures: weakness IDs. National Vulnerability Database: public weakness records. Common Vulnerability Scoring System: a source severity score.
CISA / KEV / EPSS: Cybersecurity and Infrastructure Security Agency / Known Exploited Vulnerabilities catalog / Exploit Prediction Scoring System. KEV lists flaws used in attacks. EPSS estimates a flaw's chance of use in attacks over 30 days; it does not prove your systems are affected.
HHS / HICP / CPG: US Department of Health and Human Services / Health Industry Cybersecurity Practices / Cybersecurity Performance Goals. Project links to these sources may be partial or still need review.
NIST / CSF / CIS / HIPAA: National Institute of Standards and Technology / Cybersecurity Framework / Center for Internet Security / Health Insurance Portability and Accountability Act. References do not prove compliance.
TCP / UDP / TLS / SSH / RDP / HTTP / HTTPS: Transmission Control Protocol / User Datagram Protocol / Transport Layer Security / Secure Shell / Remote Desktop Protocol / Hypertext Transfer Protocol / HTTP over TLS. These name network methods or services.

Why this score

Arithmetic explains the assessed scope, not complete coverage or safety. Unknown answers earn zero safeguards weight; review-only technical evidence adds no confirmed Exposure deduction. Administrative findings add no extra Exposure deduction. Grouped risks are counted once. Q24 follow-ups are scored once through Q24, not as separate questions.
Safeguards: 100 x 34 / 47 = 72.3404 (exact 3400/47)
Q01: No; weight 3; earned 0 of 3.
Q02: Yes; weight 3; earned 3 of 3.
Q03: Yes; weight 1; earned 1 of 1.
Q04: Yes; weight 1; earned 1 of 1.
Q05: No; weight 1; earned 0 of 1.

Q06: Yes; weight 3; earned 3 of 3.
Q07: Yes; weight 3; earned 3 of 3.
Q08: Yes; weight 3; earned 3 of 3.
Q09: Yes; weight 1; earned 1 of 1.
Q10: Yes; weight 3; earned 3 of 3.
Q11: No; weight 3; earned 0 of 3.
Q12: Yes; weight 1; earned 1 of 1.
Q13: Yes; weight 1; earned 1 of 1.
Q14: Yes; weight 1; earned 1 of 1.
Q15: No; weight 1; earned 0 of 1.
Q16: No; weight 1; earned 0 of 1.
Q17: No; weight 3; earned 0 of 3.
Q18: No; weight 1; earned 0 of 1.
Q19: Yes; weight 1; earned 1 of 1.
Q20: Yes; weight 3; earned 3 of 3.
Q21: Yes; weight 3; earned 3 of 3.
Q22: Yes; weight 1; earned 1 of 1.
Q23: Yes; weight 1; earned 1 of 1.
Q24: Yes; weight 1; earned 1 of 1.
Q25: Yes; weight 3; earned 3 of 3.
Exposure: 13 scoring entities; cap 25 points per entity.
device:LV-LT01 / R05: 6 severity points x 1.5 patient-information x 1 internet x 1 medical-device = 9.0000 (exact 9/1); issue ["R05"].
device:LV-RT01 / R10: 6 severity points x 1 patient-information x 1.5 internet x 1 medical-device = 9.0000 (exact 9/1); issue ["R10"].
device:LV-SRV01 / R03, R08: 6 severity points x 1.5 patient-information x 1 internet x 1 medical-device = 9.0000 (exact 9/1); issue ["os-support"].
device:LV-WS01 / R03: 6 severity points x 1.5 patient-information x 1 internet x 1 medical-device = 9.0000 (exact 9/1); issue ["os-support"].
device:LV-WS02 / R03: 6 severity points x 1.5 patient-information x 1 internet x 1 medical-device = 9.0000 (exact 9/1); issue ["os-support"].
cloud:1: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
cloud:2: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-LT01: 9.0000 (exact 9/1) before cap; 9.0000 (exact 9/1) after cap.
device:LV-LT02: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-MD01: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-RT01: 9.0000 (exact 9/1) before cap; 9.0000 (exact 9/1) after cap.
device:LV-SRV01: 9.0000 (exact 9/1) before cap; 9.0000 (exact 9/1) after cap.
device:LV-WS01: 9.0000 (exact 9/1) before cap; 9.0000 (exact 9/1) after cap.
device:LV-WS02: 9.0000 (exact 9/1) before cap; 9.0000 (exact 9/1) after cap.
device:LV-WS03: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-WS04: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-WS05: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:LV-WS06: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
Capped total 45.0000 (exact 45/1) x size factor 1.0000 (exact 1/1) = adjusted deduction 45.0000 (exact 45/1).
Exposure = max(0, 100 - adjusted deduction) = 55.0000 (exact 55/1).
Combined: 0.6 x Safeguards + 0.4 x Exposure = 65.4043 (exact 3074/47).
Rounded score: 65. Nearest whole number; exact .5 ties round upward.
No confirmed Critical ceiling applied; unresolved evidence still requires review.
Final score: 65/100; At risk.

Practice-area results (draft)

These practice views are a draft. They use project groups, not an official Health Industry Cybersecurity Practices (HICP) crosswalk. Safeguards uses your answers. Exposure shows known deductions only. No confirmed technical findings means unassessed, not 100. Both parts are needed for a combined score. All scores are provisional: checks are still open. Practice scores do not add or average into the overall score.

1. Email protection [draft provisional]

Safeguards: 50.00/100 (3/6 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

2. Endpoint protection [draft provisional]

Safeguards: 66.67/100 (2/3 weight)
Exposure: 91.00/100; known deductions only
Combined: 76/100; Needs attention
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

3. Access management [draft provisional]

Safeguards: 100.00/100 (10/10 weight)
Exposure: 91.00/100; known deductions only
Combined: 96/100; Good shape
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 11; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

4. Data protection [draft provisional]

Safeguards: 62.50/100 (5/8 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

5. Asset management [draft provisional]

Safeguards: 100.00/100 (1/1 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 4; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

6. Network management [draft provisional]

Safeguards: 0.00/100 (0/5 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

7. Vulnerability management [draft provisional]

Safeguards: 50.00/100 (1/2 weight)
Exposure: 73.00/100; known deductions only
Combined: 59/100; At risk
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 12; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

8. Incident response [draft provisional]

Safeguards: 100.00/100 (7/7 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

9. Network-connected medical devices [draft provisional]

Safeguards: 100.00/100 (1/1 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 1; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

10. Security oversight and governance [draft provisional]

Safeguards: 100.00/100 (4/4 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 13 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 6.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

What this score covers

The score reflects the supplied evidence and assessed scope.
Missing coverage or an informational finding does not establish safety.
- Some source or inventory coverage is unassessed.
- Some findings require verification.
- Some applied rule definitions remain drafts.

Evidence age policy

Public feeds: 8 days
Administrator observations: 30 days

Coverage requiring attention

- assessment: KEV cache is unavailable; missing coverage is not safety.
- assessment: EPSS cache is unavailable; missing coverage is not safety.
- software:1: No applicability records supplied; CVE coverage is unassessed.
- software:2: No applicability records supplied; CVE coverage is unassessed.
- software:3: No applicability records supplied; CVE coverage is unassessed.
- software:4: No applicability records supplied; CVE coverage is unassessed.

Fix First plan

Priority is finding points divided by effort, not an estimated score increase. It does not predict a drop in real risk. Caps, shared findings and the Critical score limit affect score changes. Checklist findings add no extra score loss. Ranks compare all groups. For repeated actions, we use the highest points and highest effort. We do not add their priorities. Ties use reviewed checklist links to Essential goals. These links are partial and do not prove full Cybersecurity Performance Goals (CPG) compliance. Get an estimate for unknown costs.

Do today free
No confirmed actions assigned to this group.

This month low cost
No confirmed actions assigned to this group.

Ask your vendor
#1 - R05 - device:LV-LT01
Priority: 4.5 (9 points / effort 2).
Responsible roles: IT administrator or managed service provider
Estimated cost: unknown
- Check whether device encryption is on. Encryption scrambles stored data so a key is needed to read it. If it is off, ask the IT admin to turn on a supported option. Store recovery keys safely and check the result. Plan changes to managed or medical devices with their vendor.

Copyable provider/lead request: For device:LV-LT01 (R05), please review the reported encryption gap and agree a supported encryption plan with recovery arrangements. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#2 - R10 - device:LV-RT01
Priority: 4.5 (9 points / effort 2).
Responsible roles: Device administrator or responsible vendor
Estimated cost: unknown
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.

Copyable provider/lead request: For device:LV-RT01 (R10), please review the unchanged default administrator password and agree a controlled credential change. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=False.
#3 - R07 - assessment
Priority: 3 (6 points / effort 2).
Responsible roles: IT administrator and remote-access service owner
Estimated cost: unknown
- Check each safeguard in Q17 on its own. Find remote links that are not needed. Check the login checks on each link that stays on. Plan fixes with the IT admin or vendor. A virtual private network (VPN) alone may not be enough. Do not assume that every listed service lacks multifactor authentication (MFA).

Copyable provider/lead request: For assessment (R07), please review remote-access necessity and MFA separately, and agree changes for the reported gaps. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=Q17; confirmed patient-information scope=True.
#4 - R12 - cloud:1
Priority: 3 (6 points / effort 2).
Responsible roles: Email administrator or managed service provider
Estimated cost: unknown
- Check email multifactor authentication (MFA) with the service owner. MFA adds a second proof of identity to a password. Fix confirmed gaps. Check that all accounts that need it are covered. Record any needed exceptions. Check Unknown or not applicable (NA) entries; do not treat them as enabled. Ask the IT admin which login options the service supports.

Copyable provider/lead request: For cloud:1 / Example Mail Vendor / Clinic Email (R12), please review the reported email MFA gap and agree protection for the affected accounts. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.

Tie evidence: confirmed KEV=False; reviewed Essential question links=Q01; confirmed patient-information scope=True.
#5 - R03 - device:LV-WS01
Priority: 3 (9 points / effort 3).
Responsible roles: IT administrator and system vendor
Estimated cost: unknown
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.

Copyable provider/lead request: For device:LV-WS01 (R03), please verify OS support and extended-support coverage, and plan a supported replacement or documented mitigation. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#6 - R03 - device:LV-WS02
Priority: 3 (9 points / effort 3).
Responsible roles: IT administrator and system vendor
Estimated cost: unknown
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.

Copyable provider/lead request: For device:LV-WS02 (R03), please verify OS support and extended-support coverage, and plan a supported replacement or documented mitigation. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#7 - R03, R08 - device:LV-SRV01
Priority: 3 (9 points / effort 3).
Responsible roles: IT administrator and system vendor
Estimated cost: unknown
- Check operating system support. Check if Server Message Block (SMB) file sharing is needed. If system support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Limit SMB access that is not needed. Keep needed clinical work running. Check unclear support evidence before saying that support has ended.
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.

Copyable provider/lead request: For device:LV-SRV01 (R03), please verify OS support and extended-support coverage, and plan a supported replacement or documented mitigation. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Copyable provider/lead request: For device:LV-SRV01 (R08), please review SMB on the unsupported OS and agree a supported OS plan without treating SMB presence as a confirmed exploit. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#8 - R18 - assessment
Priority: 3 (6 points / effort 2).
Responsible roles: Network administrator or managed service provider
Estimated cost: unknown
- Check if guest Wi-Fi can reach clinical systems. Ask the network admin to separate the networks and set access rules. Test that guest devices cannot reach protected systems. Check that needed work still runs.

Copyable provider/lead request: For assessment (R18), please review guest-network separation and agree restrictions protecting clinic systems. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=False.
#9 - R19 - assessment

Priority: 3 (6 points / effort 2).
Responsible roles: Network administrator or managed service provider
Estimated cost: unknown
- Check each Q16 safeguard with the network admin. Fix the settings that are confirmed to be wrong. Record the changes. Check that needed network links still work. One No answer does not prove that every safeguard is missing.

Copyable provider/lead request: For assessment (R19), please check the router safeguards individually and agree a plan for the settings actually found deficient. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=False.
#10 - R16 - assessment
Priority: 2 (6 points / effort 3).
Responsible roles: IT administrator and backup service provider
Estimated cost: unknown
- Check each Q10 safeguard on its own. Fix confirmed gaps in how often backups run. Check that backups are separate from daily work access. If Q11 is No, plan a controlled restore test. Record the result. Check Unknown answers; do not call them confirmed gaps. Plan tests so clinical work is not disrupted.

Copyable provider/lead request: For assessment (R16), please arrange a controlled restore test and record its outcome. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=Q11; confirmed patient-information scope=False.

Policy and training
No confirmed actions assigned to this group.

Verify before planning remediation

- R03 at device:LV-LT01: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-LT02: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-MD01: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-RT01: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-WS03: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-WS04: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-WS05: Verify this evidence before treating it as a confirmed gap.
- R03 at device:LV-WS06: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:1: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:2: Verify this evidence before treating it as a confirmed gap.
- R04 at device:LV-LT01: Verify this evidence before treating it as a confirmed gap.
- R04 at device:LV-SRV01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-LT01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-LT02: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-MD01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-SRV01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS02: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS03: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS04: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS05: Verify this evidence before treating it as a confirmed gap.
- R10 at device:LV-WS06: Verify this evidence before treating it as a confirmed gap.
- R11 at device:LV-MD01: Verify this evidence before treating it as a confirmed gap.
- R13 at device:LV-SRV01: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:1: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:2: Verify this evidence before treating it as a confirmed gap.
- R24 at device:LV-LT01: Verify this evidence before treating it as a confirmed gap.
- R24 at device:LV-SRV01: Verify this evidence before treating it as a confirmed gap.

Findings from supplied evidence

1. Backup safeguards gap

Rules: R16
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R16 - confirmed
Q10: Yes
Q11: No
Recommended actions:
- Check each Q10 safeguard on its own. Fix confirmed gaps in how often backups run. Check that backups are separate from daily work access. If Q11 is No, plan a controlled restore test. Record the result. Check Unknown answers; do not call them confirmed gaps. Plan tests so clinical work is not disrupted.
Responsible roles: IT administrator and backup service provider
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.DS-11 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q10/Q11 combine daily backup, separation and restore testing. Project daily frequency differs from CIS 11.2; the answers do not establish CIS isolation methods or quarterly sampling.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 11.2; 11.4; 11.5 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q10/Q11 combine daily backup, separation and restore testing. Project daily frequency differs from CIS 11.2; the answers do not establish CIS isolation methods or quarterly sampling.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 4.S.B; printed p. 21 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q10 does not distinguish frequency from separation. Backup copies are Required; contingency testing is Addressable. Daily frequency and a six-month test interval are project benchmarks.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=24
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(7)(ii)(A); 164.308(a)(7)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q10 does not distinguish frequency from separation. Backup copies are Required; contingency testing is Addressable. Daily frequency and a six-month test interval are project benchmarks. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Basic Incident Planning and Preparedness (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Backup/restore checks support recovery; they do not demonstrate complete incident readiness. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html
Source-checked project mapping: HICP 2023 - Volume 2: 4.M.D; printed pp. 50-52 (partial; recovery supplement)
Mapping scope: Partial project mapping; source checked October 30, 2026. Supplement for the restore-testing branch from medium/large-organization guidance; not a complete small-clinic recovery assessment or a mandated test interval.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol2-508.pdf#page=57

2. Guest Wi-Fi separation gap

Rules: R18
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:

R18 - confirmed
Q15: No
Recommended actions:
- Check if guest Wi-Fi can reach clinical systems. Ask the network admin to separate the networks and set access rules. Test that guest devices cannot reach protected systems. Check that needed work still runs.
Responsible roles: Network administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.IR-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q15 reports guest-network separation. Traffic filtering, alternate designs and the full architecture are not independently tested.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 12.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q15 reports guest-network separation. Traffic filtering, alternate designs and the full architecture are not independently tested.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 6.S.A; 6.S.B; printed pp. 24-25 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Guest separation is one access-boundary check; a checklist answer does not demonstrate technical isolation or a mandated topology.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=27
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(a)(1) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Guest separation is one access-boundary check; a checklist answer does not demonstrate technical isolation or a mandated topology. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Network Segmentation (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Guest separation only; effective enforcement and all critical-asset boundaries are untested. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

3. Router security safeguard gap

Rules: R19
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R19 - confirmed
Q16: No
Recommended actions:
- Check each Q16 safeguard with the network admin. Fix the settings that are confirmed to be wrong. Record the changes. Check that needed network links still work. One No answer does not prove that every safeguard is missing.
Responsible roles: Network administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q16 combines router safeguards. A combined No does not identify every failed setting or establish the documented configuration process and review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 4.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q16 combines router safeguards. A combined No does not identify every failed setting or establish the documented configuration process and review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. A combined router answer does not identify which setting failed; no specific CVE, enforced baseline or complete risk treatment is established.

Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. A combined router answer does not identify which setting failed; no specific CVE, enforced baseline or complete risk treatment is established. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Router settings are a limited configuration check; no organizational baseline is verified. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

4. Remote-access safeguard gap

Rules: R07
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R07 - confirmed
Asset id: LV-SRV01
Host: 192.168.10.10
Port: 3389
Protocol: tcp
Service: rdp
Exposure: internal
Q17: No
Recommended actions:
- Check each safeguard in Q17 on its own. Find remote links that are not needed. Check the login checks on each link that stays on. Plan fixes with the IT admin or vendor. A virtual private network (VPN) alone may not be enough. Do not assume that every listed service lacks multifactor authentication (MFA).
Responsible roles: IT administrator and remote-access service owner
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-03; PR.IR-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q17 combines remote-access necessity and MFA. Apply the CIS references to their relevant branches; a VPN alone does not satisfy the project checklist.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 6.4; 4.8 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q17 combines remote-access necessity and MFA. Apply the CIS references to their relevant branches; a VPN alone does not satisfy the project checklist.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 15 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q17 combines need for remote access and MFA; the MFA relationship applies only to that branch. Authentication does not by itself mandate a specific MFA method.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=18
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(d) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q17 combines need for remote access and MFA; the MFA relationship applies only to that branch. Authentication does not by itself mandate a specific MFA method. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Multifactor Authentication (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Only the MFA branch, for Internet-accessible accounts where safe and technically capable; not proof of phishing resistance. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

5. Email multifactor authentication gap

Rules: R12
Entity: cloud:1
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
  R12 - confirmed
    Asset id: CLOUD
    Vendor: Example Mail Vendor
    Product: Clinic Email
    Purpose: email
    Deployment: cloud
    Mfa enabled: N
Recommended actions:
  - Check email multifactor authentication (MFA) with the service owner. MFA adds a second proof of identity to a password. Fix confirmed gaps. Check that all accounts that need it are covered. Record any needed exceptions. Check Unknown or not applicable (NA) entries; do not treat them as enabled. Ask the IT admin which login options the service supports.
Responsible roles: Email administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-03 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Email MFA coverage is a project check. CIS 6.3 applies conditionally to externally exposed applications where supported; all account configurations are not verified.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 6.3 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Email MFA coverage is a project check. CIS 6.3 applies conditionally to externally exposed applications where supported; all account configurations are not verified.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 1.S.A; printed p. 10 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA evidence covers supplied accounts; phishing resistance and all authentication procedures are not verified.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=13
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(d) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA evidence covers supplied accounts; phishing resistance and all authentication procedures are not verified. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Email Security (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA is one component; filtering, forwarding and other email safeguards are outside this rule. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

6. Portable-device encryption gap

Rules: R05
Entity: device:LV-LT01
Severity: High
Scoring category: technical
Exposure risk points before entity caps and size adjustment: 9
Evidence:
  R05 - confirmed
    Asset id: LV-LT01
    Portable: Y
    Encrypted: N
Recommended actions:

- Check whether device encryption is on. Encryption scrambles stored data so a key is needed to read it. If it is off, ask the IT admin to turn on a supported option. Store recovery keys safely and check the result. Plan changes to managed or medical devices with their vendor.
Responsible roles: IT administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.DS-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 3.6 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(a)(2)(iv) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312

7. Default administrator password requires attention

Rules: R10
Entity: device:LV-RT01
Severity: High
Scoring category: technical
Exposure risk points before entity caps and size adjustment: 9
Evidence:
R10 - confirmed
Asset id: LV-RT01
Applicability: Yes
Default password changed: No
Evidence basis: Fictional Lakeview scenario explicitly states that the default administrator password is unchanged.
Evidence source: samples/lakeview_dental/assets.csv: LV-RT01; fictional scenario, not an administrator observation
Observed at: 2026-11-08T18:03:24.140304+00:00
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence

covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

8. Operating system support requires attention / SMB service on an operating system requiring support review

Rules: R03, R08
Entity: device:LV-SRV01
Severity: High
Scoring category: technical
Exposure risk points before entity caps and size adjustment: 9
Evidence:
R03 - confirmed
Asset id: LV-SRV01
Os name: Windows Server
Os version: 2012 R2
Support status: unsupported
Support basis: Fictional scenario assumption for calibration: this OS is unsupported with no extended coverage. This is not a live vendor-support determination.
Source url: https://github.com/PrimroseZoe1998/clinicshield/blob/main/samples/EXPECTED.md
Retrieved at: 2026-11-08T18:03:24.140304+00:00
Source generated at: 2026-11-08T18:03:24.140304+00:00
Extended support: confirmed_absent
R08 - confirmed
Asset id: LV-SRV01
Os name: Windows Server
Os version: 2012 R2
Support status: unsupported
Support basis: Fictional scenario assumption for calibration: this OS is unsupported with no extended coverage. This is not a live vendor-support determination.
Source url: https://github.com/PrimroseZoe1998/clinicshield/blob/main/samples/EXPECTED.md
Retrieved at: 2026-11-08T18:03:24.140304+00:00
Source generated at: 2026-11-08T18:03:24.140304+00:00
Extended support: confirmed_absent
Host: 192.168.10.10
Port: 445
Protocol: tcp
Service: smb
Exposure: internal
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
- Check operating system support. Check if Server Message Block (SMB) file sharing is needed. If system support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Limit SMB access that is not needed. Keep needed clinical work running. Check unclear support evidence before saying that support has ended.
Responsible roles: IT administrator and system vendor

Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The support-related finding also records SMB presence. It does not identify an exploitable SMB defect or require disabling every file-sharing service.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The support-related finding also records SMB presence. It does not identify an exploitable SMB defect or require disabling every file-sharing service.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. SMB presence accompanies the OS-support issue; no exploitable SMB defect or separate legal prohibition is inferred.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. SMB presence accompanies the OS-support issue; no exploitable SMB defect or separate legal prohibition is inferred. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

9. Operating system support requires attention

Rules: R03
Entity: device:LV-WS01
Severity: High
Scoring category: technical
Exposure risk points before entity caps and size adjustment: 9
Evidence:
R03 - confirmed
Asset id: LV-WS01
Os name: Windows
Os version: 10 22H2
Support status: unsupported
Support basis: Fictional scenario assumption for calibration: this OS is unsupported with no extended coverage. This is not a live vendor-support determination.
Source url: https://github.com/PrimroseZoe1998/clinicshield/blob/main/samples/EXPECTED.md
Retrieved at: 2026-11-08T18:03:24.140304+00:00
Source generated at: 2026-11-08T18:03:24.140304+00:00
Extended support: confirmed_absent
Recommended actions:

- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

10. Operating system support requires attention

Rules: R03
Entity: device:LV-WS02
Severity: High
Scoring category: technical
Exposure risk points before entity caps and size adjustment: 9
Evidence:
- R03 - confirmed
  - Asset id: LV-WS02
  - Os name: Windows
  - Os version: 10 22H2
  - Support status: unsupported
  - Support basis: Fictional scenario assumption for calibration: this OS is unsupported with no extended coverage. This is not a live vendor-support determination.
  - Source url: https://github.com/PrimroseZoe1998/clinicshield/blob/main/samples/EXPECTED.md
  - Retrieved at: 2026-11-08T18:03:24.140304+00:00
  - Source generated at: 2026-11-08T18:03:24.140304+00:00
  - Extended support: confirmed_absent

Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)

Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

Items requiring verification

1. Application support requires attention

Rules: R04
Entity: cloud:1
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Mail Vendor
Product: Clinic Email
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

2. Software version requires verification

Rules: R24
Entity: cloud:1
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: CLOUD
Vendor: Example Mail Vendor
Product: Clinic Email
Version: Unknown
Deployment: cloud
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

3. Application support requires attention

Rules: R04
Entity: cloud:2
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Backup Vendor
Product: Clinic Backup
Version: Unknown

Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

4. Software version requires verification

Rules: R24
Entity: cloud:2
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: CLOUD
Vendor: Example Backup Vendor
Product: Clinic Backup
Version: Unknown
Deployment: cloud
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.

Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

5. Application support requires attention

Rules: R04
Entity: device:LV-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: LV-LT01
Vendor: Example Remote Vendor
Product: Remote Support
Version: Unknown
Deployment: local
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

6. Default administrator password requires attention

Rules: R10
Entity: device:LV-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-LT01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

7. Software version requires verification

Rules: R24
Entity: device:LV-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: LV-LT01
Vendor: Example Remote Vendor
Product: Remote Support
Version: Unknown
Deployment: local
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the

software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

8. Operating system support requires attention

Rules: R03
Entity: device:LV-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-LT01
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS

release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

9. Default administrator password requires attention

Rules: R10
Entity: device:LV-LT02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-LT02
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

10. Operating system support requires attention

Rules: R03
Entity: device:LV-LT02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-LT02
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

11. Default administrator password requires attention

Rules: R10
Entity: device:LV-MD01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-MD01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.

Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

12. Medical-device network separation requires attention

Rules: R11
Entity: device:LV-MD01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R11 - needs review
Asset id: LV-MD01
Asset type: medical_device
Network segment: medical
Separation verified: Unknown
Evidence basis: Medical-device network separation has not been verified.
Recommended actions:
- Ask the device vendor, clinical owner and network admin which links the medical device needs. For a confirmed gap, agree a network design and access rules. Check that allowed traffic and needed work still run. A network segment label alone is not a reason to change device links. Do not disrupt needed clinical work.
Responsible roles: Network administrator and medical-device vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.IR-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Supplied medical-device separation evidence supports a project segmentation finding. The rule does not assess the complete architecture or vendor constraints.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 12.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Supplied medical-device separation evidence supports a project segmentation finding. The rule does not assess the complete architecture or vendor constraints.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 9.S.A; 6.S.A; printed pp. 24, 30 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Medical-device separation evidence is limited; effective access enforcement and complete device security are not verified.

Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=33
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(a)(1) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Medical-device separation evidence is limited; effective access enforcement and complete device security are not verified. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Network Segmentation (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Only the supplied medical-device boundary; no demonstration of all critical-asset segmentation. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

13. Operating system support requires attention

Rules: R03
Entity: device:LV-MD01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-MD01
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

14. Operating system support requires attention

Rules: R03
Entity: device:LV-RT01
Severity: Info

Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-RT01
Os name: Unknown
Os version: Unknown
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

15. Application support requires attention

Rules: R04
Entity: device:LV-SRV01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: LV-SRV01
Vendor: Example Dental Vendor
Product: Practice Manager
Version: Unknown
Deployment: local
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor

Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

16. Default administrator password requires attention

Rules: R10
Entity: device:LV-SRV01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-SRV01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not

a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

17. Clinical-system multifactor authentication gap

Rules: R13
Entity: device:LV-SRV01
Severity: Info
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R13 - needs review
Asset id: LV-SRV01
Vendor: Example Dental Vendor
Product: Practice Manager
Purpose: practice_management
Deployment: local
Mfa enabled: NA
Recommended actions:
- Check MFA coverage and supported login options with the app owner. Fix confirmed gaps. Record limits and exceptions. Check Unknown or NA entries; do not treat them as enabled. Plan changes with clinical users and vendors so needed access still works.
Responsible roles: Application administrator and system vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-03 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Clinical MFA is assessed from Q07 and supplied software. CIS 6.3 is conditional on external exposure and support; it is not a universal mandate for every internal application.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 6.3 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Clinical MFA is assessed from Q07 and supplied software. CIS 6.3 is conditional on external exposure and support; it is not a universal mandate for every internal application.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 3.S.A; printed p. 18 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Clinical MFA evidence covers the supplied application; authentication procedures and all access paths are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=21
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(d) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Clinical MFA evidence covers the supplied application; authentication procedures and all access paths are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Multifactor Authentication (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Conditional on independently verified Internet accessibility and safe technical capability; internal systems alone do not establish this scope. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

18. Software version requires verification

Rules: R24
Entity: device:LV-SRV01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: LV-SRV01

Vendor: Example Dental Vendor
Product: Practice Manager
Version: Unknown
Deployment: local
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

19. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.

Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

20. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS02
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not

a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

21. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS03
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS03
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

22. Operating system support requires attention

Rules: R03
Entity: device:LV-WS03
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-WS03
Os name: Windows
Os version: 11 24H2
Support status: unknown

Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

23. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS04
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS04
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence

covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

24. Operating system support requires attention

Rules: R03
Entity: device:LV-WS04
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-WS04
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

25. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS05
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS05
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

26. Operating system support requires attention

Rules: R03
Entity: device:LV-WS05
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-WS05
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support

has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

27. Default administrator password requires attention

Rules: R10
Entity: device:LV-WS06
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: LV-WS06
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)

Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

28. Operating system support requires attention

Rules: R03
Entity: device:LV-WS06
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: LV-WS06
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308